GUIA DE FUNDAMENTOS · OPEN SOURCE · MIT

Regulatório Financeiro Brasileiro

Fundamentos completos do sistema financeiro nacional, Pix, DICT, Open Finance, Open Insurance, compliance e padrões de implementação — escrito do zero, sem assumir conhecimento prévio.

Pix · DICT · Open Finance · OPIN · FAPI 2.0 · mTLS · ICP-Brasil · Compliance

Paulo Marcos Lucio

Engenheiro Java pleno · Consultor em integrações regulatórias BR

github.com/Paulo-Marcos-Lucio

Sumário

Você pode ler de ponta a ponta (recomendado pra primeira vez) ou usar como referência — cada capítulo é autocontido. As Partes I a IV constroem a base teórica; a V cobre compliance e operação; a VI é o cheat sheet pra call.

Parte I — Fundamentos do SFN

Cap. 1 O que é um banco, no fundo

Cap. 2 Como o dinheiro circula entre bancos

Cap. 3 Quem regula quem: BCB, CMN, Susep, CVM

Cap. 4 A pirâmide regulatória: Lei → Resolução → Circular → Manual

Parte II — Pix

Cap. 5 Por que o Pix existe (o problema que resolveu)

Cap. 6 Arquitetura macro do Pix

Cap. 7 Anatomia de uma transação Pix passo-a-passo

Cap. 8 Modalidades de Pix

Cap. 9 Regras críticas: irreversibilidade, MED, e devolução

Cap. 10 Pix Automático

Cap. 11 Pix por Aproximação (Pix NFC)

Cap. 12 Pix Saque e Pix Troco

Parte III — DICT

Cap. 13 O que é DICT, e por que ele existe

Cap. 14 Tipos de chave em detalhe

Cap. 15 Atores e papéis no DICT

Cap. 16 Operações do DICT

Cap. 17 Regras de cache, segurança e SLA

Parte IV — Open Finance Brasil

Cap. 18 O que é Open Finance e por que existe

Cap. 19 As 4 fases do Open Finance

Cap. 20 Atores e papéis

Cap. 21 FAPI 2.0 + Brasil profile

Cap. 22 Consentimento (Consents): a peça central

Cap. 23 Iniciação de pagamentos (Fase 3) em detalhe

Parte V — Open Insurance + Compliance

Cap. 24 Open Insurance Brasil (OPIN)

Cap. 25 Compliance regulatório: o que é, na prática

Cap. 26 Tipos de risco regulatório

Cap. 27 Multas, sanções e enforcement

Cap. 28 mTLS e ICP-Brasil em profundidade

Cap. 29 Logs, auditoria e observabilidade regulatória

Cap. 30 Padrões de implementação que sinalizam senioridade

PARTE I — Fundamentos do Sistema Financeiro Brasileiro

> Esta parte assume **conhecimento zero** de finanças. Começamos do princípio: o que é um banco, como o dinheiro circula entre eles, e quem fica olhando pra ninguém roubar nem quebrar tudo.

Capítulo 1 — O que é um banco, no fundo

Esquece por um minuto a fachada de mármore e os caixas eletrônicos. Um banco, em essência, é **uma empresa que faz três coisas**:

1. **Guarda dinheiro de gente** (depósitos)
2. **Empresta dinheiro pra outra gente** (crédito)
3. **Move dinheiro de A pra B** (pagamentos)

A mágica é que o banco usa o dinheiro guardado de quem deposita pra emprestar pra outros — e cobra juros mais altos no empréstimo do que paga no depósito. Essa diferença (o **spread bancário**) é a fonte primária de receita.

Por que isso importa pra um engenheiro?

Porque cada produto digital de banco — Pix, TED, débito, cartão, conta corrente — é **uma forma de executar uma dessas três operações**. Quando você implementa um cliente DICT ou um iniciador Pix, você está construindo um pedaço da operação **3 (mover dinheiro)**.

> 💡 **Sacada importante:** o saldo da sua conta não é dinheiro físico guardado num cofre com seu nome. É só **uma linha num banco de dados** dizendo "o banco deve X reais a este CPF". Toda a infraestrutura de pagamentos é, no fundo, um sistema distribuído de **atualização sincronizada de números em bancos de dados de instituições diferentes**.

Tipos básicos de instituição financeira

Não tem só "banco" no Brasil. A regulação separa em vários tipos:

Tipo	Sigla	O que faz	Exemplo
Banco múltiplo	—	Pode fazer todas as operações (depósito, crédito, câmbio, etc.)	Itaú, Bradesco, Santander
Banco comercial	—	Foco em depósitos à vista e crédito de curto prazo	(cada vez mais raro isolado)
Caixa Econômica	—	Banco público com mandato social (FGTS, loterias, habitacional)	Caixa
Cooperativa de crédito	—	Banco "associativo", clientes são donos	Sicoob, Sicredi
Instituição de Pagamento	**IP**	NÃO pode emprestar, só movimentar dinheiro	Mercado Pago, PicPay (na origem)
Sociedade de Crédito Direto	**SCD**	Empresta dinheiro PRÓPRIO (sem captar de terceiros)	várias fintechs de crédito
Sociedade de Empréstimo entre Pessoas	**SEP**	Plataforma P2P de crédito	Nexoos, Biva
Banco Digital	—	É só um banco múltiplo sem agência física	Nubank, Inter, C6

🔑 **Termo que você VAI ouvir em call: PSP — Prestador de Serviços de Pagamento**. É o termo guarda-chuva pro que você seria se sua empresa estiver no Pix. Inclui banco, IP, cooperativa — qualquer um autorizado pelo BCB a operar Pix.

Por que tantos tipos?

A diferença está em **o que cada uma pode fazer com o dinheiro do cliente** e **quanto capital próprio é exigido pra operar**. Banco múltiplo pode emprestar — então precisa de muito capital de reserva pra absorver calote. IP só movimenta — capital exigido é menor.

Pra você como dev, o que muda é **qual regulação aplica**. Um banco enfrenta regras mais pesadas que uma IP. Mas TODAS que mexem com Pix seguem as **mesmas regras Pix do BCB**, independente do tipo.

Capítulo 2 — Como o dinheiro circula entre bancos

Quando você manda R$ 100 pro seu primo no Inter e você é cliente do Itaú, o que acontece?

A versão simplificada

1. Você dá ordem ao Itaú: "tira R$ 100 da minha conta e manda pro CPF X no Inter"

2. Itaú **debita** R$ 100 da sua conta (linha no DB do Itaú)
3. Itaú avisa o Inter: "mandei R$ 100 pro CPF X de vocês"
4. Inter **credita** R$ 100 na conta do seu primo (linha no DB do Inter)
5. Mas o Inter agora tá "devendo" R$ 100 pro Itaú? Como zera essa dívida?

A resposta é o **Sistema de Pagamentos Brasileiro (SPB)**.

O Sistema de Pagamentos Brasileiro (SPB)

O SPB é a **infraestrutura nacional** que liquida (zera) as dívidas entre instituições. Ele existe pra resolver o problema 5 acima: como instituições diferentes acertam contas entre si sem ter que entregar saco de dinheiro toda hora.

Os componentes principais:

Sistema	O que faz	Quem opera	Janela
STR — Sistema de Transferência de Reservas	Liquidação **bruta em tempo real** entre bancos	BCB	24/7
SILOC	Liquidação **diferida** (em lotes) de TED, boletos, cheques	BCB	Diário
SPI — Sistema de Pagamentos Instantâneos	Liquidação **instantânea** do Pix	BCB	24/7/365
CIP	Câmara interbancária privada (TEDs, boletos)	CIP S.A.	Diário

> 💡 **Bruta vs Líquida:** Liquidação **bruta** = cada operação é zerada uma a uma, na hora. **Líquida** = junta todas as operações do dia, calcula o saldo final, e zera 1 vez. STR é bruta (real-time). SILOC é líquida (acumula e fecha no fim do dia).

Onde o Pix se encaixa

O Pix usa o **SPI**. Quando você manda Pix:

1. Seu PSP (digamos, Itaú) **debita** seu saldo
2. Itaú envia mensagem padrão Pix pelo **SPI**
3. SPI verifica se tem grana na **conta de reserva** do Itaú no BCB
4. SPI **transfere** dos reservas do Itaú pros reservas do Inter (movimentação dentro do BCB)
5. SPI avisa Inter
6. Inter **credita** seu primo

Toda transação Pix passa pelo SPI. **O BCB é o operador do SPI** — ou seja, o BCB sabe de TODAS as transações Pix do país. Isso tem implicações de privacidade, segurança e regulação que vamos ver depois.

"Conta de reserva" — o que é isso?

Toda instituição financeira autorizada a participar do SPB precisa manter **uma conta no Banco Central** com saldo em reais. É essa conta que é movimentada quando o SPI liquida um Pix.

Pense assim: o BCB é "o banco dos bancos". Se Itaú e Inter fossem clientes do mesmo banco (BCB), uma transferência entre eles seria só um lançamento contábil interno. É exatamente isso que acontece via SPI.

> 🔑 **Termo pra call: "conta reservas"** ou **"conta no BCB"**. Quando alguém disser "o banco precisa ter saldo em reservas pra liquidar a operação", agora você entende.

Capítulo 3 — Quem regula quem: BCB, CMN, Susep, CVM

O Brasil tem **4 órgãos** que regulam o sistema financeiro, cada um cuidando de um pedaço:

1. CMN — Conselho Monetário Nacional

- **O que é:** o "alto comando" da política monetária e financeira do país
- **Composição:** Ministro da Fazenda + Ministro do Planejamento + Presidente do BCB
- **O que faz:** define **diretrizes gerais** — política monetária, taxa de juros básica, política cambial
- **Não regula no detalhe:** delega isso pro BCB e CVM
- **Em call:** raramente alguém menciona o CMN. É político, não operacional.

2. BCB — Banco Central do Brasil

- **O que é:** autarquia federal autônoma. **O órgão que VOCÊ vai conviver.**
- **O que faz:**
  - Executa a política monetária (define Selic na prática via Copom)
  - Emite a moeda
  - **Regula e fiscaliza bancos, IPs, cooperativas, fintechs de pagamento**
  - **Opera o SPB e o SPI (Pix)**
  - **Mantém o DICT**
  - **Coordena o Open Finance**

- **Em call:** sempre. Quando alguém diz "o regulador", está falando do BCB.

> 🔑 **Estrutura do BCB que VOCÊ vai esbarrar:**
>
> - **Departamento de Operações Bancárias e de Sistema de Pagamentos (Deban)** — cuida do Pix, DICT, SPB
> - **Departamento de Regulação do Sistema Financeiro (Denor)** — escreve as Resoluções e Circulares
> - **Departamento de Supervisão de Conduta (Decon)** — fiscaliza condutas (multas vêm daqui)

3. CVM — Comissão de Valores Mobiliários

- **O que é:** regulador do **mercado de capitais** (ações, fundos, debêntures)
- **O que faz:** fiscaliza Bolsa, corretoras, fundos de investimento
- **Em call de Pix/Open Finance/DICT:** raramente menciona. Mais relevante se o seu cliente for corretora ou gestora.

4. Susep — Superintendência de Seguros Privados

- **O que é:** regulador do **mercado de seguros**, capitalização e previdência aberta
- **O que faz:**
  - Fiscaliza seguradoras
  - **Coordena o Open Insurance (OPIN)**
- **Em call:** sempre que falar de Open Insurance / OPIN é Susep.

Resumo simples

Setor	Regulador
Bancos, fintechs, Pix, Open Finance	**BCB**
Seguros, OPIN	**Susep**
Bolsa, fundos, corretoras	**CVM**
Diretrizes macro do país	**CMN**

Capítulo 4 — A pirâmide regulatória: Lei → Resolução → Circular → Manual

Quando você lê "conforme a Resolução BCB nº XXX" e fica perdido, é por causa dessa hierarquia. Saber isso te coloca em outro patamar em call:

```
┌──────────────────────────────────────────────────────┐
│  LEI                                                  │
│  (passa pelo Congresso, demora anos)                  │
│  Ex: Lei 4.595/64 — criou o SFN; Lei 12.865/13 — IPs  │
└──────────────────┬───────────────────────────────────┘
                   ▼
┌──────────────────────────────────────────────────────┐
│  RESOLUÇÃO CMN                                        │
│  (CMN decide a diretriz alto nível)                   │
│  Ex: define que pagamentos instantâneos vão existir   │
└──────────────────┬───────────────────────────────────┘
                   ▼
┌──────────────────────────────────────────────────────┐
│  RESOLUÇÃO BCB                                        │
│  (BCB regulamenta, com força quase de lei)            │
│  Ex: Resolução BCB 1/2020 — criou o Pix               │
└──────────────────┬───────────────────────────────────┘
                   ▼
┌──────────────────────────────────────────────────────┐
│  CIRCULAR / INSTRUÇÃO NORMATIVA BCB                   │
│  (detalhamento operacional)                           │
│  Ex: detalhes técnicos de SLA, mensageria             │
└──────────────────┬───────────────────────────────────┘
                   ▼
┌──────────────────────────────────────────────────────┐
│  MANUAL OPERACIONAL                                   │
│  (especificação técnica — JSON schemas, XML, fluxos)  │
│  Ex: Manual de Operação do DICT, Manual do SPI        │
│  Aqui você como engenheiro vive 90% do tempo          │
└──────────────────────────────────────────────────────┘
```

💡 **O que isso significa pra você na prática:**

- **Resoluções** mudam raramente, são "constitucionais" do tema
- **Manuais** mudam frequentemente (versões a cada poucos meses)
- **Cliente sério vai te perguntar "qual versão do Manual do DICT vocês implementam?"** — saber responder é sinal de senioridade
- Quando alguém disser "aderência regulatória", está falando de cumprir TODA a pirâmide acima, não só o manual

Onde achar essa documentação (oficial e gratuita)

- **Resoluções e Circulares BCB:** site do BCB, seção "Normas e padrões" → busca por número

- **Manuais técnicos do Pix/DICT/SPI:** site do BCB, seção "Pix" → "Especificações técnicas"
- **Open Finance Brasil:** `openfinancebrasil.org.br` (regras + Developer Portal com OpenAPI specs)
- **Open Insurance:** `opensusep.susep.gov.br`

> ⚠️ **Atenção:** os números, datas e versões específicas mudam. Sempre verifique a versão vigente antes de citar em call. "Conforme a versão atual do Manual do DICT" é mais seguro que "conforme o Manual versão 2.5" — porque pode já ter saído a 2.6.

Glossário rápido da Parte I

Termo	Significado (versão crua)
SFN	Sistema Financeiro Nacional — todas as instituições reguladas
SPB	Sistema de Pagamentos Brasileiro — infra nacional de pagamentos
SPI	Sistema de Pagamentos Instantâneos — onde o Pix roda
STR	Sistema de Transferência de Reservas — liquidação real-time entre bancos
PSP	Prestador de Serviços de Pagamento — qualquer um que opera Pix
IF	Instituição Financeira (genérico)
IP	Instituição de Pagamento — fintech que só movimenta, não empresta
BCB	Banco Central do Brasil
CMN	Conselho Monetário Nacional
Susep	Reguladora de seguros
CVM	Reguladora de mercado de capitais
Conta reservas	Conta de cada IF no BCB usada pra liquidar entre instituições
Spread bancário	Diferença entre juros que banco cobra emprestando e paga captando
Liquidação bruta	Cada operação liquidada individualmente em tempo real
Liquidação líquida	Operações agregadas e liquidadas em saldo no fim do dia

📍 **Onde estamos:** acabamos de cobrir o "mapa" do sistema financeiro. Você sabe quem é quem, quem regula o quê, e por onde o dinheiro passa entre instituições. As próximas partes mergulham em **cada produto regulatório individualmente** — começando pelo Pix.

PARTE II — Pix: do conceito à última atualização

> O Pix é o **carro-chefe** da modernização do sistema de pagamentos brasileiro. Se você vai prestar consultoria em pagamentos no Brasil em 2026, **você tem que dominar Pix**. Esta parte cobre da motivação histórica até as últimas evoluções (Pix Automático, NFC).

Capítulo 5 — Por que o Pix existe (o problema que resolveu)

Antes de novembro de 2020, mover dinheiro entre bancos no Brasil era ruim. Sério.

O cenário antes do Pix

Forma	Custo	Tempo	Limites
TED	R$ 5–15 (PF), R$ 30+ (PJ)	Horário comercial, mesma janela liquidação	Sem limite, mas SLA travado
DOC	R$ 5–10	D+1 (chega só no próximo dia útil)	Limite até R$ 4.999,99
Boleto	R$ 1–5 (emitir)	Compensação até D+3	Limite alto
Cheque	R$ 0–2	Compensação D+1 a D+3	—

Problemas:

1. **Caro** — fintech tinha que repassar custo TED ao cliente
2. **Lento** — fim de semana, feriado, depois das 17h: nada funcionava
3. **Excludente** — quem não tinha conta corrente (35% dos brasileiros, à época) ficava de fora
4. **Privado** — a CIP (operadora privada) cobrava taxas dos bancos pra liquidar TEDs

O objetivo declarado do BCB ao criar o Pix

Em ordem de prioridade, segundo o próprio BCB:

1. **Promover competição e inclusão financeira** — fintech pequena pode competir com banco grande
2. **Reduzir custo de transação** (em escala nacional, isso libera bilhões/ano)
3. **Acelerar o ecossistema** (e-commerce, microempreendedor, P2P)

4. **Substituir o uso de papel-moeda** (custo de fabricação, transporte, segurança da Casa da Moeda)

Resultado, em números (qualitativos)

- Pix passou TED, DOC, boleto e cartão em volume de transações em poucos anos
- Brasil virou referência mundial em pagamentos instantâneos (estudado pelo FMI, BIS)
- Um produto regulatório virou **infraestrutura crítica** — um dia inteiro de Pix offline pararia o varejo do país

> 🔑 **Pra call:** quando alguém perguntar "por que Pix é estratégico?", você pode responder em uma frase: *"Porque é a primeira infraestrutura nacional de pagamentos pública, gratuita pra pessoa física, 24/7, e que nivelou o jogo entre incumbentes e fintechs."*

Capítulo 6 — Arquitetura macro do Pix

Vamos olhar quem fala com quem.

Os atores

```
        ┌──────────────────────────────────────┐
        │              BANCO CENTRAL           │
        │  ┌──────────┐    ┌────────────────┐  │
        │  │   SPI    │    │   DICT         │  │
        │  │ (liquid.)│    │ (chaves)       │  │
        │  └──────────┘    └────────────────┘  │
        └────────▲────────────────▲────────────┘
                 │                │
            ┌────┘                └──────┐
            │                            │
┌───▼────────┐                      ┌────▼────┐
│ PSP do     │   mensageria SPI     │ PSP do  │
│ Pagador    │◄────────────────────►│ Recebedor │
│ (ex: Itaú) │                      │ (ex: Inter)│
└──▲─────────┘                      └────▲────┘
   │                                     │
┌──▼─────────┐                      ┌────▼────┐
│  Pagador   │                      │ Recebedor │
│ (cliente   │                      │ (cliente  │
│  Itaú)     │                      │  Inter)   │
└────────────┘                      └─────────┘
```

Os 3 papéis principais

Papel	Quem é	O que faz
PSP do Pagador	Banco/IP do quem manda	Inicia a operação, debita o pagador
PSP do Recebedor	Banco/IP do quem recebe	Credita o recebedor
BCB	Banco Central	Opera SPI (liquidação) e DICT (chaves)

Os dois sistemas centrais do BCB

1. **SPI** — Sistema de Pagamentos Instantâneos. **Liquida** o dinheiro entre os bancos. É a "linha de produção" do Pix.
2. **DICT** — Diretório de Identificadores de Contas Transacionais. **Resolve a chave** (CPF, e-mail, etc.) pro número de conta de verdade. É o "DNS" do Pix.

> 💡 **Analogia que funciona em call:** o **DICT é como o DNS da internet**. Você digita `google.com` (chave), o DNS resolve pro IP `142.250.x.x` (conta real). No Pix, você digita o e-mail do recebedor (chave), o DICT resolve pro CPF + agência + conta dele.

Por onde a transação passa fisicamente

1. App do Pagador → API do PSP do Pagador
2. PSP do Pagador → DICT (consulta a chave)
3. PSP do Pagador → SPI (envia ordem de pagamento)
4. SPI → liquida (movimenta reservas no BCB)
5. SPI → PSP do Recebedor (notifica)
6. PSP do Recebedor → app do Recebedor (notifica push)

Tudo isso precisa acontecer em **menos de 10 segundos** segundo o SLA do BCB.

Capítulo 7 — Anatomia de uma transação Pix passo-a-passo

Vamos pegar o caso real: **João (cliente Itaú) manda R$ 50 pra Maria (cliente Nubank), usando a chave-celular dela**.

Fluxo completo (timestamps reais)

```
T=0ms      [João] abre app Itaú, digita celular da Maria, R$ 50
T=10ms     [App Itaú] valida formato, envia ao backend
T=20ms     [Itaú] consulta DICT: GET /entries/+5511999999999
T=200ms    [DICT] responde: { ispb: "18236120", agência: "0001",
                              conta: "12345-6", nome: "Maria Silva",
                              cpf: "***.123.456-**" }
T=210ms    [App Itaú] mostra "Confirma pagamento de R$ 50,00 a
                      Maria S***?". João confirma.
T=300ms    [Itaú] valida saldo, debita R$ 50 da conta de João
T=350ms    [Itaú] monta mensagem Pix (pacs.008) e envia ao SPI
T=600ms    [SPI] valida mensagem, debita reservas Itaú no BCB
T=700ms    [SPI] credita reservas Nubank no BCB
T=800ms    [SPI] envia mensagem ao Nubank com a credencial
T=1100ms   [Nubank] credita R$ 50 na conta de Maria
T=1200ms   [Nubank] envia push notification a Maria
T=1300ms   [Nubank] confirma ao SPI: "creditado"
T=1500ms   [SPI] confirma ao Itaú: "operação completa"
T=1600ms   [Itaú] mostra a João: "Pagamento realizado"
```

Tempo total típico: **1–3 segundos**. SLA máximo do BCB: **10 segundos**.

As mensagens (padrão ISO 20022)

O Pix usa o padrão internacional **ISO 20022** pra mensageria. As mensagens chave:

Código	Tipo	Quando
`pacs.008`	Pagamento (FI to FI Customer Credit Transfer)	PSP do Pagador → SPI → PSP do Recebedor
`pacs.002`	Status Report	Confirmação ou rejeição
`pacs.004`	Devolução (Payment Return)	MED, cancelamento
`camt.029`	Resolução de investigação	Resposta de investigação manual

> 🔑 **Pra call: "ISO 20022"** e **"pacs.008"** são termos que sinalizam senioridade. Se a fintech está construindo cliente Pix do zero, eles vão lidar com esses formatos. Saber que existe e o papel deles já te diferencia.

Onde os erros mais comuns acontecem

1. **Chave não encontrada** (DICT retorna 404) — recebedor não tem chave cadastrada com aquele identificador
2. **Saldo insuficiente** (PSP do Pagador rejeita) — antes mesmo de chegar no SPI
3. **Timeout no SPI** — SPI deve responder em < 5s, se passar disso o Pagador devolve erro

4. **Conta destino fechada/bloqueada** — PSP do Recebedor rejeita, SPI estorna
5. **Fraude detectada** — PSP do Pagador ou Recebedor pode bloquear pré-emissão

---

Capítulo 8 — Modalidades de Pix

Não tem "um" Pix. Tem várias formas de iniciar.

1. Pix por chave

A mais comum. Pagador digita ou seleciona a chave do recebedor. **Tipos de chave**:

Tipo	Formato	Quem usa	Limite/conta
CPF	11 dígitos	PF	1 por CPF
CNPJ	14 dígitos	PJ	1 por CNPJ
E-mail	RFC válido	PF e PJ	5 (PF) ou 20 (PJ)
Celular	+55 + DDD + número	PF e PJ	5 (PF) ou 20 (PJ)
EVP (Chave Aleatória)	UUID	PF e PJ	sem limite específico

> 💡 **EVP — "Endereço Virtual de Pagamento"** é o nome formal da chave aleatória (UUID). Se você não quer expor seu CPF/celular/e-mail, gera uma EVP, manda pra quem te paga. Boa prática pra anúncios públicos.

2. Pix por dados bancários (sem chave)

Pagador digita: ISPB do banco + agência + conta + tipo (corrente/poupança) + CPF/CNPJ. Funciona, mas é UX ruim — quase ninguém usa.

> 🔑 **ISPB — Identificador do Sistema de Pagamentos Brasileiro** é o "código do banco" no Pix. Itaú = 60701190, Nubank = 18236120, Inter = 00416968. Cada PSP tem o seu.

3. Pix por QR Code estático

Recebedor gera **uma vez** um QR Code que carrega: chave + valor (opcional) + identificador. Imprime, cola na parede do bar. Cliente paga lendo com câmera.

- Vantagem: simples, offline-friendly pro recebedor
- Desvantagem: valor pré-definido (ou em branco) e ID estático — difícil reconciliar

4. Pix por QR Code dinâmico

Recebedor gera **um QR diferente por venda**, com **valor exato + identificador único**. O QR aponta pra uma URL HTTPS do PSP do recebedor que retorna o JWS com os dados.

- Vantagem: reconciliação perfeita, valor sempre correto
- Padrão pra **e-commerce e maquininha física**

5. Pix Copia-e-Cola

É o **payload do QR Code dinâmico em formato texto**. Você gera o "BR Code" (string codificada), cola no chat, no e-mail. O pagador cola no app do banco e paga. Mesma estrutura técnica do QR dinâmico, sem a imagem.

6. Pix Saque e Pix Troco

- **Pix Saque:** você usa o Pix pra **sacar dinheiro** num caixa de varejista (mercado, farmácia). O varejista te dá dinheiro físico, e você manda Pix pra ele de igual valor.
- **Pix Troco:** você compra algo + saca um valor adicional na mesma operação Pix.
- Ambos: o BCB pretendeu **substituir o saque em ATM**. Adoção é menor que o esperado.

7. Pix Automático *(novo, lançado out/2025)*

Cobertura completa no **Capítulo 10**. É a versão Pix do **débito automático**.

8. Pix por Aproximação (NFC) *(novo, em rollout)*

Cobertura completa no **Capítulo 11**. Pagar Pix encostando o celular na maquininha, sem QR.

Capítulo 9 — Regras críticas: irreversibilidade, MED, e devolução

Aqui mora a maior dor de cabeça operacional do Pix.

Irreversibilidade

Pix é **irreversível por padrão**. Uma vez liquidado, o dinheiro saiu da sua conta e foi pra do recebedor. **Não tem chargeback** como em cartão de crédito.

Por que: o BCB queria velocidade e finalidade da liquidação. Se fosse reversível, o sistema teria que segurar valores, complicaria tudo.

Implicação: se você manda Pix pro CPF errado, o dinheiro foi. **Você precisa pedir devolução voluntária**.

Devolução voluntária

O recebedor pode (e em muitos casos deve) **devolver voluntariamente** valores recebidos por engano. Não é obrigatório por lei pra todo caso, mas:

- Bancos boniticios têm fluxo de "devolução" no app
- Tecnicamente é uma nova transação Pix do recebedor pro pagador (mensagem `pacs.004`)

MED — Mecanismo Especial de Devolução

Foi criado pra **fraudes e golpes**. Funciona assim:

1. Pagador denuncia ao seu PSP que foi vítima de golpe
2. PSP do Pagador abre **MED** (Mecanismo Especial de Devolução) via SPI
3. PSP do Recebedor é obrigado a **bloquear** o valor (se ainda tiver na conta)
4. Investigação ocorre (pode ser manual)
5. Se confirmado golpe, valor é devolvido ao pagador

Prazos (verificar versão atual do Manual): a devolução via MED tem janela específica — *"até X dias úteis após a transação"*, conforme manual.

> ⚠️ **Atenção em call:** se cliente pergunta "como funciona devolução", a resposta tem 3 camadas:
>
> 1. **Voluntária** — recebedor devolve por boa vontade
> 2. **MED por fraude/golpe** — caminho regulatório, bloqueio de saldo, prazos curtos
> 3. **Investigação por erro operacional** — caso a caso

Bloqueio cautelar

Se o PSP do recebedor detecta padrão suspeito (recebimento muito acima do perfil, vários CPFs pagando ao mesmo CNPJ pequeno, etc.), pode **bloquear preventivamente**. Isso é regulamentado e há prazos.

Capítulo 10 — Pix Automático

> Lançado em **outubro de 2025**. É o **substituto regulatório do débito automático**. Provavelmente vai dominar cobrança recorrente nos próximos anos.

O que é

Pix Automático permite que um recebedor (digamos, sua academia) **debite seu Pix de forma recorrente** mediante **autorização prévia** do pagador.

Diferença vs débito automático tradicional

Característica	Débito Automático	Pix Automático
Onde mora	Banco (relacionamento bilateral)	Pix (regulado pelo BCB)
Cadastro	Manual no banco	Pix QR ou link
Mudança de banco	Refazer tudo	Carrega o consentimento
Cancelamento	Liga pra empresa	Botão no app do banco, qualquer hora
Falhas	Recebedor tenta de novo manual	Retentativas automatizadas reguladas
Valor variável	Limitado	Suportado (ex: conta de luz)
Padrão	Sem padrão (cada banco diferente)	Padrão BCB unificado

Atores e fluxo

1. **Recebedor** (ex: academia) tem CNPJ habilitado pra Pix Automático e gera um **QR de autorização**
2. **Pagador** lê o QR no app do banco, vê os termos (valor, periodicidade, prazo, máximo), **autoriza**
3. PSP do Pagador registra o **consentimento** com o BCB
4. Na data agendada, recebedor **dispara cobrança** via SPI
5. SPI valida que existe consentimento ativo e dentro dos limites
6. Pix é executado normalmente

Tipos de cobrança suportados

- **Valor fixo recorrente** (assinatura mensal de academia)
- **Valor variável** (conta de água, luz)
- **Periodicidade flexível** (semanal, mensal, anual)
- **Tentativa-única** (boleto-like)
- **Retentativas automáticas** (até N tentativas se falhar por saldo insuficiente, com janela definida)

Cancelamento

Pagador pode cancelar **a qualquer momento** pelo app do PSP. Recebedor é notificado.

Por que isso é estratégico

Boletos têm taxa alta (R$ 1–5 por emissão), tempo de compensação D+1, e UX ruim no cliente. Débito automático é cativo do banco. **Pix Automático combina baixo custo + UX boa + portabilidade entre bancos.**

> 🔑 **Pra call:** quando uma fintech de cobrança (ex: subscriber-billing, gateways tipo Vindi, Iugu) busca consultoria em Pix Automático em 2026, o que ela quer entender é: **como migrar a base de boletos recorrentes pra Pix Automático sem quebrar reconciliação**. Esse é o produto.

Onde seu projeto `pix-automatico-reference` se encaixa

Você implementou:

- **Saga orquestrada** pra criação de consentimento → emissão da cobrança → liquidação
- **Outbox** pra garantir que evento de pagamento confirmado vire baixa no ERP do cliente
- **Idempotência em 3 camadas** porque retentativas no Pix Automático são REGRA, não exceção

Esses são os **3 padrões críticos** que diferenciam um cliente Pix Automático production-grade de uma POC.

Capítulo 11 — Pix por Aproximação (Pix NFC)

> **Spec recém-publicada pelo BCB.** Em rollout. Janela curta pra se posicionar como referência.

O que é

Pagar Pix **encostando o celular** na maquininha do varejista, sem precisar abrir QR. Mesma UX do **Apple Pay / Google Pay** mas usando o protocolo Pix por baixo.

Como funciona tecnicamente

Usa **NFC + HCE (Host Card Emulation)**. Resumo:

1. Maquininha do varejista emite sinal NFC com **payload de cobrança Pix**
2. App do banco no celular do pagador lê via HCE
3. App valida, mostra "Pagar R$ X em Loja Y?"
4. Pagador autoriza (biometria/PIN)

5. App envia Pix normalmente via SPI

A diferença do QR é **só o canal de captura do payload**. A liquidação é Pix puro.

Por que importa

- **Velocidade na fila** — encostar > escanear QR
- **Inclusão** — celulares sem câmera boa, idosos com dificuldade pra mira
- **Maquininha simples** — não precisa de tela, só NFC + chip pequeno

Status atual

Em **fase de adoção** — alguns bancos já lançaram, outros estão integrando. Maquininhas de pagamento (Stone, Cielo, Rede) estão rolando atualizações de firmware.

Sua aposta com `pix-nfc-reference`

Como a spec é nova, **quase não tem implementação open source pública**. Quem publicar referência sólida agora vira **a fonte canônica** que devs novos vão consultar. Janela de 6–12 meses até virar commodity.

Capítulo 12 — Pix Saque e Pix Troco

> Cobertura curta porque adoção é baixa. Mas se aparecer em call, você sabe responder.

Pix Saque

Você quer dinheiro físico. Vai num varejo conveniado (farmácia, mercado), pede saque de R$ X. O caixa registra como "venda Pix Saque" no PDV. Você lê o QR e paga R$ X via Pix. Caixa te entrega R$ X em dinheiro.

Quem ganha: o varejista recebe **um pequeno percentual** do BCB pelo serviço (compensa o trabalho do caixa).

Pix Troco

Compra de R$ 30 + saque de R$ 50 = pagamento Pix de R$ 80, varejista te dá R$ 50 em dinheiro de troco.

Por que existem

Substituir o saque em ATM (caro pra banco manter, escasso em algumas regiões). Adoção tem sido lenta — costume cultural e UX ainda em ajuste.

Resumo da Parte II — pontos pra ter na ponta da língua

Pergunta provável	Resposta de 1 frase
"Por que o Pix é importante?"	Substituiu TED/DOC pagos por infra pública gratuita 24/7, nivelou competição banco vs fintech
"Quem opera o Pix?"	O BCB opera SPI (liquidação) e DICT (chaves); PSPs são as instituições autorizadas a transacionar
"O Pix é reversível?"	Não, irreversível por padrão. Devolução só voluntária ou via MED em caso de fraude
"O que muda com Pix Automático?"	Substitui débito automático: padrão BCB, cancelamento livre, portabilidade entre bancos, valor variável
"Por que Pix usa ISO 20022?"	Padrão internacional de mensageria financeira — facilita interop e auditoria
"Qual a vantagem do Pix NFC?"	Velocidade no PDV (encostar > escanear QR), igual Apple Pay mas com infra Pix

📍 **Onde estamos:** acabamos de cobrir tudo de Pix do conceito ao novíssimo. Você sabe a história, os atores, os fluxos, as modalidades, e os termos-chave. **A próxima parte mergulha no DICT** — o "DNS" do Pix, e o tema do seu segundo repo.

PARTE III — DICT: o "DNS" do Pix

> O **DICT — Diretório de Identificadores de Contas Transacionais** é o sistema central do BCB que **resolve uma chave Pix** (CPF, e-mail, celular, EVP) **pra os dados reais da conta**. Sem DICT, você não tem Pix por chave. Esta é a base do seu segundo repo (`dict-client-reference`).

Capítulo 13 — O que é DICT, e por que ele existe

O problema

Pra pagar alguém via Pix, eu preciso saber o **endereço da conta** do recebedor: ISPB do banco + agência + conta + tipo de conta + CPF/CNPJ. Se eu tivesse que pedir tudo isso pra alguém **toda vez** antes de pagar, a UX seria igual TED. Tortura.

A solução

Substituir esse endereço gigante por um identificador simples que a pessoa já tem: CPF, e-mail, celular, ou um UUID aleatório (EVP).

O DICT é o **diretório central** que mapeia:

```
chave (e-mail / CPF / celular / EVP)  →  dados da conta real
```

Cada PSP precisa **consultar o DICT** pra resolver a chave do recebedor antes de mandar Pix.

Por que centralizado, não distribuído

Tecnicamente daria pra fazer com DNS-like distribuído. Mas o BCB centralizou pra:

1. **Garantir unicidade** (uma chave só pode estar registrada num PSP por vez)
2. **Auditoria** — qualquer mudança de chave passa pelo BCB
3. **Antifraude** — BCB consegue detectar padrões cross-bank
4. **Soberania regulatória** — chave é informação financeira sensível

> 🔑 **Pra call:** "DICT é o registry central de chaves do Pix. Cada PSP tem que ser cliente do DICT pra resolver chaves do Pagador antes de iniciar uma transação."

Capítulo 14 — Tipos de chave em detalhe

Tipo	Formato exato	Validações importantes	Limite por titular
CPF	`12345678901` (11 dígitos)	Algoritmo de validação CPF; PF apenas	1 chave por CPF
CNPJ	`12345678000190` (14 dígitos)	Algoritmo CNPJ; PJ apenas	1 chave por CNPJ
E-mail	`pessoa@exemplo.com` (RFC 5322)	Validação de formato; verificação de posse via OTP	5 (PF) ou 20 (PJ)
Celular	`+5511999999999` (E.164)	Verificação de posse via SMS OTP	5 (PF) ou 20 (PJ)
EVP	`123e4567-e89b-12d3-a456-426614174000` (UUID v4)	Gerada pelo PSP, sempre única	sem limite específico (mas há limites totais por titular)

Verificação de posse

Antes de uma chave virar dela, o PSP precisa **provar que o titular possui aquele identificador**:

- **E-mail:** envia OTP pro endereço, titular cola o código no app
- **Celular:** envia SMS com OTP
- **CPF/CNPJ:** validação documental (já é da titularidade declarada na conta)
- **EVP:** não precisa, gerada pelo próprio PSP

Sem essa verificação, dava pra registrar `presidente@gov.br` como sua chave Pix. O DICT recusa registros sem comprovação.

Portabilidade de chave

Uma chave pode **migrar entre PSPs**. Ex: você tem `meu@email.com` cadastrado no Itaú, quer migrar pro Inter.

Fluxo:

1. Você pede portabilidade no Inter
2. Inter manda **claim** ao DICT
3. DICT notifica Itaú: "estão pedindo essa chave, você libera?"
4. Itaú tem prazo pra **aceitar ou contestar**
5. Se aceitar (ou prazo vencer sem contestação), DICT transfere a chave
6. A partir desse momento, transações pra `meu@email.com` caem na conta Inter

> 💡 **Esse fluxo de claim é parte do DICT que você implementou no `dict-client-reference`.** Tem regras temporais específicas (X dias úteis pra contestar) que estão no Manual do DICT.

Reivindicação por posse

Se alguém registra `seu@email.com` indevidamente em outro PSP (e você consegue provar posse no seu PSP), você pode **reivindicar** com prioridade. É um sub-fluxo de claim com evidências.

Capítulo 15 — Atores e papéis no DICT

```
┌──────────────────────────────────────┐
│              DICT (BCB)              │
│  ┌──────────────────────────┐        │
│  │ Diretório de Chaves      │        │
│  │ (banco de dados central) │        │
│  └──────────────────────────┘        │
└──────────▲──────────▲────────────────┘
           │          │
           │ mTLS     │ mTLS
           │          │
┌──────────┴──────┐  ┌──────┴──────────┐
│ PSP DETENTOR    │  │ PSP SOLICITANTE │
│ (dono atual     │  │ (quem consulta  │
│  da chave)      │  │  pra pagar)     │
└─────────────────┘  └─────────────────┘
```

Papéis

- **PSP Detentor (Holder):** o PSP onde a chave está registrada hoje. Responde pelas operações daquela chave.
- **PSP Solicitante (Inquirer):** PSP que está consultando a chave (porque o cliente dele quer pagar pra essa chave).
- **PSP Doador / PSP Reivindicante:** em fluxos de portabilidade — quem está soltando a chave (doador) e quem está pegando (reivindicante).

Como o PSP se conecta ao DICT

- **mTLS obrigatório** com **certificado ICP-Brasil** (cadeia de confiança da Autoridade Certificadora Raiz Brasileira)
- Endpoint do DICT é REST/JSON (em algumas operações **XML + JWS** — assinatura digital de payload)
- IP de origem precisa estar **whitelistado** no BCB (registrado em fila de homologação)

🔑 **ICP-Brasil — Infraestrutura de Chaves Públicas Brasileira** é a PKI nacional. Certificados emitidos por ACs credenciadas (Serasa, Certisign, etc.). Você precisa de um certificado válido emitido sob essa cadeia pra falar com DICT, SPI e qualquer infra crítica do governo.

Capítulo 16 — Operações do DICT

O DICT expõe um conjunto de operações REST. Vamos pelos principais:

1. Consulta (Lookup)

`GET /entries/{key}` — operação **mais frequente**. Toda transação Pix começa com isso.

Request:

```
GET /entries/+5511999999999 HTTP/1.1
Host: dict.bcb.gov.br
PI-RequestingParticipant: 12345678
Authorization: ICP-Brasil mTLS cert
```

Response (200 OK):

```
{
  "Entry": {
    "Key": "+5511999999999",
    "KeyType": "PHONE",
    "Account": {
      "Participant": "18236120",
      "Branch": "0001",
      "AccountNumber": "12345678",
      "AccountType": "CACC",
      "OpeningDate": "2023-05-12T00:00:00Z"
    },
    "Owner": {
      "Type": "NATURAL_PERSON",
      "TaxIdNumber": "***12345***",
      "Name": "Maria S***"
    },
    "CreationDate": "2024-03-01T10:00:00Z",
    "KeyOwnershipDate": "2024-03-01T10:00:00Z"
  }
}
```

Response (404 Not Found): chave não existe.

> ⚠️ **Privacidade:** o DICT **mascara** o nome e CPF retornados. Você nunca recebe o CPF completo do recebedor — só os 6 dígitos do meio. Isso é proteção LGPD.

2. Cadastro (Create Entry)

`POST /entries` — quando seu cliente pede pra registrar uma chave. Você (PSP Detentor) registra com seu próprio mTLS.

Validações que o DICT faz:

- A chave já existe em outro PSP? Se sim, rejeita (precisa ser claim)
- Tem limites de chaves por titular? Não pode passar
- Os dados são consistentes? CPF dono bate com a conta?

3. Atualização (Update Entry)

`PATCH /entries/{key}` — pra atualizar dados (nome do titular, número da conta dentro do mesmo PSP).

4. Remoção (Delete Entry)

`DELETE /entries/{key}` — quando cliente pede pra excluir a chave dele.

5. Reivindicação / Portabilidade (Claim)

`POST /claims` — quando outro PSP quer pegar uma chave que tá com você.

Sub-operações:

- `POST /claims/{id}/confirm` — PSP doador confirma (libera)
- `POST /claims/{id}/cancel` — PSP doador contesta (bloqueia)
- `POST /claims/{id}/complete` — PSP reivindicante finaliza

Com prazos temporais específicos no manual.

6. Reportes de Infração / Fraude

`POST /infraction-reports` — registrar suspeita de uso fraudulento de uma chave.

`POST /fraud-markers` — marcar uma chave/conta como envolvida em fraude (compartilha info entre PSPs).

> 💡 **Esses dois últimos são parte do `dict-claim` no seu projeto** — o grupo Resilience4j com retry conservador. São operações de baixo volume mas alta criticidade.

Capítulo 17 — Regras de cache, segurança e SLA

Cache regulatório

O DICT permite que PSPs façam **cache local** das respostas de lookup, mas **com limites máximos definidos pelo BCB**:

Tipo de chave	TTL máximo permitido
CPF	(verificar manual atual)
CNPJ	(verificar manual atual)
E-mail	(verificar manual atual)
Celular	(verificar manual atual)
EVP	(verificar manual atual)

> ⚠️ **Atenção:** os valores exatos de TTL **mudam entre versões do Manual**. Não decora valor — decora o **conceito**: o BCB define um teto, e o PSP escolhe um TTL menor ou igual a esse teto.

> 🔑 **No seu projeto** `dict-client-reference` — você implementou `RegulatoryCacheTtlPolicy` que **clampa o TTL configurado ao máximo BCB**. É essa regra. Documentado em `docs/compliance/bcb-mapping.md`.

Por que cache importa

DICT cobra (sim, cobra) por consulta acima de um limite mensal. **Cache reduz custo + latência + carga no DICT**. Mas se você cachear demais (acima do TTL máximo), ficaria com dados desatualizados — e isso **viola a regra do BCB**, gerando multa.

Segurança

- **mTLS obrigatório** com cert ICP-Brasil
- **Whitelisting de IP** no BCB
- Algumas operações têm **JWS** (assinatura JSON) ou **XML assinado** sobreposto ao mTLS (defesa em profundidade)
- Logs de auditoria de TODAS as chamadas — exigência regulatória, BCB pode requisitar

SLA

O BCB define limites de latência e disponibilidade pro próprio DICT, e exige que PSPs respeitem certas regras:

- **Rate limit** por IP/CNPJ (excesso = 429)
- **Tempo máximo de resposta** que PSP deve aceitar antes de fallback
- **Disponibilidade mínima** que PSP deve garantir aos clientes

Fraude e marcação

Quando uma chave é envolvida em fraude:

1. PSP do pagador registra `infraction-report`
2. PSP do recebedor é notificado
3. Investigação ocorre
4. Se confirmada, a chave/conta recebe um `fraud-marker`
5. Outros PSPs ao consultar essa chave **veem o marker** e podem rejeitar transações

Isso é o **antifraude colaborativo do BCB** — informação cruza PSPs via DICT.

Resumo da Parte III — pontos pra call

Pergunta provável	Resposta pronta
"O que é DICT?"	"Registry central de chaves Pix mantido pelo BCB; resolve chave (CPF/e-mail/celular/EVP) pros dados de conta reais"
"Como o PSP fala com DICT?"	"REST/JSON sobre mTLS com cert ICP-Brasil, IP whitelisted; algumas ops com JWS/XML assinado"
"Por que cache é importante?"	"Reduz latência, custo e carga; mas tem TTL máximo regulatório por tipo de chave que não pode ser ultrapassado"
"O que é claim?"	"Fluxo de portabilidade ou reivindicação de chave entre PSPs com prazo de contestação pelo doador"
"Como funciona antifraude no DICT?"	"PSPs registram infraction reports e fraud markers; informação compartilhada entre todos via DICT"

> 📍 **Onde estamos:** Pix e DICT cobertos. Você tem domínio do que sustenta os repos `pix-automatico-reference` e `dict-client-reference` da Suíte. **A próxima parte é o Open Finance Brasil** — o terreno dos próximos repos.

PARTE IV — Open Finance Brasil

> **Open Finance** é o sistema regulado pelo BCB que permite **compartilhamento padronizado de dados financeiros** entre instituições, com **consentimento explícito do cliente**. É o tema mais complexo deste material — vale ler com calma.

Capítulo 18 — O que é Open Finance e por que existe

O problema

Antes do Open Finance, sua relação com seu banco era **um silo**. Os dados das suas contas, cartões, financiamentos, investimentos viviam dentro do banco e **só ele** podia usá-los pra te oferecer produtos.

Se você queria mudar de banco, abrir conta em fintech, contratar empréstimo melhor, ou usar app agregador de finanças — você precisava **inserir tudo manualmente**, ou no máximo dar sua **senha** pro app fazer "screen scraping" (ilegal e inseguro).

A solução

O BCB criou o **Open Finance Brasil** baseado em um princípio: **os dados financeiros são do cliente, não do banco**. Logo, o cliente deve poder:

1. **Autorizar** uma instituição (Receptora) a acessar seus dados em outra (Detentora)
2. **Iniciar pagamentos** a partir de aplicativos de terceiros
3. **Cancelar a qualquer momento**
4. **Ter portabilidade real** entre instituições

Diferença entre Open Banking e Open Finance

- **Open Banking** = só dados de **conta bancária e cartão** (escopo inicial)
- **Open Finance** = dados bancários **+ investimentos + seguros + previdência + câmbio**

O Brasil **começou como Open Banking em 2021** e evoluiu pra **Open Finance** ao longo de 2022–2024.

> 🔑 **Pra call:** quando alguém usa "Open Banking" e "Open Finance" como sinônimos no Brasil, **estão se referindo ao mesmo programa do BCB hoje**. O termo evoluiu, o programa se chama oficialmente "Open Finance Brasil".

Por que importa pra você

Open Finance é **a maior oportunidade de consultoria regulatória do mercado brasileiro em 2026**. Toda fintech, banco, seguradora e gestora precisa estar tecnicamente conformante. **Consultoria nessa área = R$ 50–200k por engajamento médio**, com tickets de 12+ meses não sendo raros.

Capítulo 19 — As 4 fases do Open Finance

O programa foi rolling-out em 4 fases. Cada uma adicionou um conjunto de dados/operações disponíveis:

Fase 1 — Dados das próprias instituições (canais e produtos)

> **Lançada 2021.**

Cada banco/IF expõe **publicamente** dados sobre:

- Canais de atendimento (agências, ATMs, telefones)
- Produtos e serviços (taxas de cartão, juros de empréstimo)

Esses dados são **abertos** (sem consentimento), pra qualquer um consultar. Útil pra comparadores de produtos.

Fase 2 — Dados cadastrais e transacionais (consent-based)

> **Lançada 2021.**

Dados **do cliente**, com consentimento dele:

- Cadastrais (nome, endereço, telefone, e-mail)
- Conta corrente (saldo, extrato)
- Cartão de crédito (limite, fatura, transações)
- Operações de crédito (empréstimos, financiamentos)

Aqui entra o conceito de **consentimento granular** — cliente escolhe **quais dados** compartilha, **com quem**, e **por quanto tempo**.

Fase 3 — Iniciação de pagamentos (PISP)

> **Lançada 2022.**

App de terceiros pode **iniciar uma transação Pix** em nome do cliente, sem o cliente precisar abrir o app do banco. Exemplo: e-commerce que tem botão "Pagar com Open Finance" — você autoriza dentro do próprio site, sem sair pra app de banco.

> 🔑 **PISP — Payment Initiation Service Provider** (Iniciador de Pagamento). É um **novo tipo de instituição** criada pelo Open Finance, regulada pelo BCB, que pode iniciar pagamentos sem ser dona da conta.

Fase 4 — Investimentos, seguros, previdência, câmbio

> **Lançada 2023–2024.**

Compartilhamento estendido:

- Saldo e posições em investimentos (corretoras, fundos)
- Apólices de seguros, previdência aberta
- Operações de câmbio

> 💡 **Importante:** o nome "Fase 4" hoje significa basicamente o **escopo expandido de dados**. Os repos `pix-automatico-reference` e o futuro `open-finance-payments-reference` mexem principalmente com **Fase 3 (iniciação)**, já que pagamento é Fase 3.

Resumo das fases

Fase	Foco	Consentimento?
1	Dados públicos das IFs (canais, produtos)	Não
2	Dados do cliente (cadastro, conta, cartão, crédito)	Sim, granular
3	Iniciação de pagamentos por terceiros	Sim, por transação
4	Investimentos, seguros, previdência, câmbio	Sim

Capítulo 20 — Atores e papéis

```
                ┌──────────────────────────────┐
                │     DIRETÓRIO CENTRAL OFB    │
                │  (registry de participantes) │
                │  https://data.directory.openfinancebrasil.org.br
                └──────▲──────────────────────▲──┘
                       │ registro             │
                       │                      │
   ┌──────────────────┴──────────┐   ┌────────┴──────────────┐
   │   DETENTORA                 │   │    RECEPTORA          │
   │   (banco do cliente)        │◄──┤  (fintech, agregador) │
   │   ex: Itaú                  │   │    ex: GuiaBolso      │
   │                             │   │                       │
   │   expõe APIs                │   │   consome APIs        │
   │   /consents                 │   │   solicita consent    │
   │   /accounts                 │   │   acessa dados        │
   │   /payments                 │   │                       │
   └──────────▲──────────────────┘   └──────▲────────────────┘
              │                             │
              │  consentimento              │  jornada UX
              │  + autenticação             │
              │                             │
              └──────────┬──────────────────┘
                         │
                   ┌─────▼─────┐
                   │ CLIENTE   │
                   │ (titular  │
                   │ dos dados)│
                   └───────────┘
```

Detalhe dos papéis

Detentora (Account Servicing Payment Service Provider — ASPSP)

- A instituição que **detém** os dados/conta do cliente
- Geralmente é o banco principal do cliente
- **Expõe** as APIs Open Finance: `/consents`, `/accounts`, `/payments`, etc.
- **Autentica** o cliente (login, biometria, MFA) durante a jornada de consentimento
- Responsável por **validar consent** em cada chamada

Receptora / Iniciadora (Receiver — Third Party Provider — TPP)

- Instituição que **quer acessar** dados ou iniciar pagamentos em nome do cliente
- Pode ser **qualquer instituição autorizada** pelo BCB (banco, fintech, agregador, e-commerce)
- **Consome** as APIs da Detentora
- Subdivide em:
  - **Account Information Service Provider (AISP)** — só lê dados (Fase 2 e 4)

  - **Payment Initiation Service Provider (PISP)** — inicia pagamentos (Fase 3)

Diretório Central (OFB Directory)

- Registry **único e oficial** de participantes do Open Finance Brasil
- Mantido pela **estrutura de governança do Open Finance** (consórcio público-privado supervisionado pelo BCB)
- Toda instituição autorizada está lá com:
  - Cert TLS de produção
  - Endpoints (Discovery URL, FAPI URL)
  - Software statements (SSA)
  - Status de conformidade
- **Você precisa consultar o Diretório** pra saber qual a URL do FAPI do banco com o qual quer integrar

> 🔑 **Pra call: "Diretório Central"** e **"SSA — Software Statement Assertion"** são termos altamente específicos de Open Finance. Mencioná-los corretamente já te coloca acima da maioria.

Capítulo 21 — FAPI 2.0 + Brasil profile

> O Open Finance Brasil **não inventou um padrão técnico do zero**. Adotou o **FAPI** (Financial-grade API), um perfil OAuth 2.0 + OpenID Connect criado pela OpenID Foundation pra finanças. E aplicou customizações = **"Brasil profile"**.

O que é FAPI

FAPI = Financial-grade API. É um perfil de OAuth 2.0/OIDC com **segurança reforçada** pra cenários financeiros:

- Autenticação mútua TLS (**mTLS**) ou DPoP
- **Request Object** assinado (JWS)
- **Response Mode** assinado
- **PAR — Pushed Authorization Requests**
- **JARM — JWT Secured Authorization Response Mode**

Foi originalmente criado pra Open Banking UK. Brasil adotou o **FAPI 2.0** (versão evoluída, mais segura).

Por que FAPI

OAuth 2.0 puro tem fragilidades documentadas (token leak via redirect, code injection, replay). FAPI fecha essas brechas exigindo:

- **PKCE obrigatório** (proteção contra interceptação)
- **mTLS sender-constrained tokens** (token só funciona com o cert que o pegou)
- **Request signing** (cliente assina a requisição, servidor valida assinatura)
- **JARM** (resposta também assinada — proteção contra MITM)

Brasil profile — o que tem além do FAPI base

O Brasil profile adiciona/customiza:

- **DCR — Dynamic Client Registration** com **SSA do Diretório Central**
- **Consent flow específico** (mais granular que o padrão)
- **Operações brasileiras** (Pix, dados de cartão, etc.) — não tem no FAPI vanilla
- **Validação de cert ICP-Brasil** em pontos específicos

Em resumo, pra um dev

Quando você ouvir "FAPI 2.0 + Brasil profile":

- É um conjunto de regras técnicas em cima de OAuth 2.0
- **Padronizadas pelo Open Finance Brasil** (governança privada com supervisão BCB)
- Especificações estão no **Developer Portal**: `openfinancebrasil.org.br`
- Existem **suites de conformance** que você roda pra provar que sua implementação está correta

> 🔑 **Pra call:** "Implementamos o **FAPI 2.0 perfil Brasil** com PAR + JARM + mTLS sender-constrained". Essa frase é instant credibility com qualquer time técnico de fintech séria.

Capítulo 22 — Consentimento (Consents): a peça central

O Open Finance gira em torno de **consentimento explícito do cliente**. Vamos detalhar.

Anatomia de um consentimento

Um consent contém:

Campo	Significado
`consentId`	UUID único
`loggedUser`	CPF do cliente
`permissions`	Lista granular: `ACCOUNTS_READ`, `CREDIT_CARDS_READ`, `PAYMENTS_INITIATE`, etc.
`expirationDateTime`	Quando o consent expira (até 12 meses pra dados)
`transactionFromDateTime`	Janela de dados acessíveis (mais antigo)
`transactionToDateTime`	Janela de dados acessíveis (mais novo)
`creditor`	Pra Fase 3 — recebedor do pagamento
`payment`	Pra Fase 3 — valor, descrição

Jornada de UX (simplificada)

```
[Cliente está no app/site da Receptora]
   ▼
[Receptora chama POST /consents na Detentora]
   ▼
[Receptora redireciona cliente pra Detentora]
   ▼
[Cliente faz login na Detentora (banco dele)]
   ▼
[Cliente vê tela: "Esta empresa pede acesso a X, Y, Z. Confirma?"]
   ▼
[Cliente confirma com biometria/PIN]
   ▼
[Detentora redireciona cliente de volta pra Receptora]
   ▼
[Receptora agora tem authorization code]
   ▼
[Receptora troca code por access_token via FAPI]
   ▼
[Receptora pode chamar /accounts, /payments, etc., usando o token]
```

Estados de um consent

```
AWAITING_AUTHORIZATION (criado, aguardando cliente autorizar)
    ▼
AUTHORISED (cliente autorizou)
    ▼
CONSUMED (consent atendeu propósito — comum em Fase 3, pagamento single-use)
    OU
REJECTED (cliente recusou)
    OU
EXPIRED (passou da expirationDateTime)
    OU
REVOKED (cliente cancelou ativamente)
```

Granularidade

Cliente pode autorizar APENAS **algumas permissões** de uma lista. Exemplo: cliente pode autorizar leitura de **conta corrente** mas não de **cartão de crédito**. Isso obriga a UX da Receptora a explicar **qual exatamente é o escopo** que pede.

Cancelamento

Cliente pode cancelar o consent **a qualquer momento** pelo app da Detentora (e pela Receptora também). Isso revoga os tokens.

> ⚠️ **Implicação técnica importante:** sua Receptora precisa **tratar 401 Unauthorized vindo de uma API que ANTES funcionava** — o consent pode ter sido revogado entre uma chamada e outra. Não é exceção rara, é fluxo esperado.

Capítulo 23 — Iniciação de pagamentos (Fase 3) em detalhe

Esta é a parte que mais te interessa pro `open-finance-payments-reference`.

O caso de uso clássico

E-commerce com botão "Pagar com Open Finance":

1. Cliente está no checkout do e-commerce
2. Clica "Pagar com Open Finance"
3. Seleciona seu banco (Itaú)
4. É redirecionado pro Itaú, faz login, vê tela: *"Loja XYZ pede pagamento de R$ 150 da sua conta corrente. Confirma?"*
5. Confirma com biometria

6. Itaú **inicia o Pix** (na verdade um Pix pelo SPI, mas iniciado por terceiro)
7. Cliente é redirecionado de volta pro e-commerce
8. E-commerce recebe webhook confirmando pagamento

Por que isso é melhor que QR estático tradicional

- **Não precisa abrir app do banco e copiar/colar Pix copia-e-cola**
- **UX no próprio site** (com 1 redirect rápido)
- **Reconciliação automática** (e-commerce sabe imediatamente do pagamento)
- **Padrão regulatório** (não dependente de bandeira de cartão)

Atores adicionais da Fase 3

- **Iniciadora (PISP)** — quem inicia o pagamento. Pode ser:
  - O próprio e-commerce, se autorizado pelo BCB
  - Um intermediário (gateway de pagamento certificado)
- **Detentora (banco do cliente)** — executa o Pix
- **Recebedor** — pode ser o e-commerce ou um terceiro

Anatomia da operação `/payments`

```
POST /payments/v1/pix/payments HTTP/1.1
Host: matls-api.banco.com.br
Authorization: Bearer <access_token mTLS sender-constrained>
Content-Type: application/jwt

<JWS assinado>
   ↓ decodificado:
{
  "data": {
    "consentId": "urn:bancoex:C1DD33123",
    "creditorAccount": {
      "ispb": "12345678",
      "issuer": "0001",
      "number": "1234567",
      "accountType": "CACC"
    },
    "localInstrument": "DICT",
    "payment": {
      "amount": "150.00",
      "currency": "BRL"
    },
    "remittanceInformation": "Pedido #98765"
  }
}
```

A Detentora valida:

- Consent ainda autorizado?
- Conta debitada bate com o consent?
- Saldo OK?
- Transação dentro dos limites do consent?

Se tudo OK, dispara o Pix via SPI normalmente.

Pix Automático via Open Finance

> **Atenção: aqui se conecta com a Parte II.**

O **Pix Automático** lançado em out/2025 **se beneficia diretamente do Open Finance Fase 3**: a iniciadora (ex: gateway de cobrança recorrente) usa Open Finance pra obter consentimento de **N pagamentos futuros**, e dispara cada um sem nova autorização do cliente.

Esta é a razão do seu `pix-automatico-reference` mencionar "Open Finance Fase 4" no posicionamento — porque o caso de uso real combina os dois.

Riscos e SLA

- **SLA da Detentora:** o BCB exige disponibilidade alta (verificar percentual atual no manual — tipicamente acima de 99,5%) das APIs Open Finance
- **Multas por descumprimento de SLA** podem ser aplicadas
- **Conformance test** obrigatório antes de ir pra produção (homologação)

Resumo da Parte IV — pontos pra call

Pergunta provável	Resposta pronta
"Open Finance vs Open Banking?"	"Brasil começou como Open Banking em 2021 e expandiu pra Open Finance em 2023+ — hoje cobre dados bancários, cartão, crédito, investimentos, seguros e iniciação de pagamentos"
"Quais as fases?"	"Fase 1: dados públicos. Fase 2: dados do cliente. Fase 3: iniciação de pagamentos (PISP). Fase 4: investimentos, seguros, previdência"
"O que é FAPI 2.0 + Brasil profile?"	"Perfil OAuth 2.0/OIDC reforçado pra finanças, com mTLS sender-constrained, request signing, PAR e JARM. Brasil customiza com SSA do Diretório, validação ICP-Brasil e ops específicas"
"Como funciona consent?"	"É autorização granular do cliente, com permissões específicas e prazo. Cliente autoriza no banco (Detentora) durante redirect, pode revogar a qualquer hora"
"Diferença Fase 3 vs Pix tradicional?"	"Fase 3 permite que terceiro (e-commerce, gateway) **inicie** o Pix em nome do cliente, com consent. O Pix em si roda pelo SPI normal. UX fica dentro do app do terceiro"
"O que é Diretório Central?"	"Registry oficial de participantes do Open Finance Brasil, supervisionado pelo BCB. Toda instituição autorizada está lá com SSA, certs, endpoints"

📍 **Onde estamos:** Open Finance dominado. Você sabe os atores, os fluxos, FAPI, consent, e como Pix Automático se encaixa. **Próxima parte: Open Insurance + Compliance.**

PARTE V — Open Insurance + Compliance e Operação

Capítulo 24 — Open Insurance Brasil (OPIN)

> O **OPIN** é o equivalente do Open Finance, mas para o **mercado segurador** brasileiro. Regulado pela **Susep** (não pelo BCB), com escopo, atores e fases próprios.

O que é

Sistema regulado pela Susep que permite **compartilhamento padronizado de dados de seguros, previdência aberta e capitalização**, com consentimento do cliente. Mesma filosofia do Open Finance: dados são do cliente, não da seguradora.

Por que existe

- **Portabilidade:** dificuldade pra trocar de seguradora porque cliente não consegue mover histórico
- **Comparação:** apólices entre seguradoras eram opacas
- **Inovação:** insurtechs queriam construir produtos de comparação e gestão, mas dependiam de screen scraping ou parcerias bilaterais

Diferenças vs Open Finance

Característica	Open Finance (BCB)	Open Insurance (Susep)
Regulador	BCB	Susep
Diretório	OFB Directory	OPIN Directory
Foco	Banco, conta, crédito, pagamentos	Seguros, previdência, capitalização
Padrão técnico	FAPI 2.0 + Brasil profile	FAPI 2.0 + Brasil profile (similar, mas com customizações de seguros)
Iniciação de pagamentos	Sim (Fase 3)	Sim (também tem fluxo de pagamento de prêmio)

Atores no OPIN

- **Sociedade Detentora** — seguradora ou EAPC (Entidade Aberta de Previdência Complementar) que detém os dados
- **Sociedade Receptora** — recebe os dados (pode ser seguradora, corretora, insurtech)
- **Sociedade Iniciadora de Serviços de Pagamento** — análoga ao PISP do Open Finance, mas pra produtos de seguro
- **Cliente** — segurado, beneficiário, ou participante de previdência

Fases do OPIN

(Verificar versão atual do roadmap Susep — fases evoluíram desde lançamento.)

Em linhas gerais:

1. **Dados públicos** — produtos, canais, condições de seguros
2. **Dados cadastrais e de apólices** — apólices ativas, sinistros, beneficiários
3. **Iniciação de operações** — solicitação de cotação, contratação, pagamento de prêmio
4. **Produtos especializados** — saúde, previdência, capitalização

FAPI-CIBA — uma especificidade do OPIN

OPIN usa **CIBA — Client-Initiated Backchannel Authentication**. É um modo de OAuth onde:

- A autorização **não acontece via redirect no browser**
- A Detentora dispara uma **notificação fora-de-banda** pro cliente (push no app, SMS)
- Cliente aprova **diretamente no app da seguradora**, sem voltar pra origem
- Receptora recebe callback quando aprovado

Por que CIBA importa pra seguros: muitos cenários de seguro acontecem em **call center** ou **corretor presencial**. O cliente **não está no celular dele** quando o atendente solicita o consent. Com CIBA, o atendente dispara solicitação, o celular do cliente vibra com push, ele aprova lá.

> 🔑 **Pra call:** "OPIN usa **FAPI-CIBA** porque a jornada de venda de seguro frequentemente é assistida (call center, corretor). CIBA permite consent fora do canal de origem."

Por que isso é uma oportunidade pra você

OPIN tem **menos consultoria especializada que Open Finance**. Mercado é menor mas com **menos competição**. Seu repo `open-insurance-transmissor-reference` planejado pode ser referência canônica em PT-BR — quase ninguém publicou material sério.

Capítulo 25 — Compliance regulatório: o que é, na prática

> "Compliance" é um daqueles termos que todo mundo usa e ninguém define direito. Vamos definir.

Compliance, na regulação financeira BR, é cumprir 4 camadas

1. **Regulação prudencial** — ter capital e estrutura mínima
2. **Regulação de conduta** — operar dentro das regras (KYC, AML, transparência)
3. **Regulação técnica** — APIs, mensageria, padrões (Pix, OF, DICT)
4. **Regulação informacional** — relatórios periódicos pro BCB/Susep

Pra **TI/engenharia**, as camadas 3 e 4 são onde você vive. Camadas 1 e 2 são de Compliance Officer.

O que sua implementação técnica precisa garantir

Aspecto	Exemplo concreto
Conformidade ao manual técnico	Schemas JSON/XML batem com a versão vigente
Logs auditáveis	Cada operação grava log com timestamp, request ID, resultado
Rastreabilidade end-to-end	Trace ID que cruza Pix → Open Finance → DICT
Segurança de comunicação	mTLS válido, certs ICP-Brasil, sem fallback inseguro
Resiliência	Retentativas controladas, circuit breakers, idempotência
Privacidade	Mascaramento de dados sensíveis em logs e responses
Disponibilidade	Uptime acima do SLA regulatório

> 🔑 **Pra call: "Conformidade técnica ≠ conformidade regulatória completa**. A engenharia entrega conformidade técnica; o jurídico/Compliance Officer entrega o resto. Mas se a engenharia errar, a multa cai na empresa toda."

Auditoria: o que perguntam em call de compliance

Quando uma fintech contrata você pra adequação, é provável que perguntem:

1. **"Como vocês logam transações Pix?"** — formato JSON estruturado, retenção mínima de X anos

2. **"Como vocês mascaram dados sensíveis?"** — CPF parcial, número de conta parcial em logs
3. **"Vocês têm dashboards de SLA das APIs?"** — Grafana/Datadog mostrando p95/p99/disponibilidade
4. **"Qual a estratégia de retentativa?"** — backoff exponencial, max attempts, idempotência
5. **"Como vocês detectam fraude?"** — heurísticas, scoring, integração com fraud markers do DICT
6. **"Vocês têm runbook pra incidentes regulatórios?"** — quando contatar BCB, prazos de notificação

Se você tem boa resposta pra essas 6 perguntas, **você passa a entrevista técnica de qualquer fintech séria**.

Capítulo 26 — Tipos de risco regulatório

Quando alguém fala "risco" no mundo regulatório, pode estar falando de várias coisas:

Risco Operacional

Falha em processos, pessoas, sistemas. Ex: SPI ficar 30min indisponível pra um PSP, transações ficam empilhadas.

Mitigação técnica: circuit breakers, fallback gracioso, monitoring de SLA, capacity planning.

Risco de Liquidez

Ficar sem saldo na conta de reservas no BCB pra liquidar Pix. Pix com saldo insuficiente nas reservas fica **bloqueado pelo SPI**.

Mitigação: capital reservado, monitoring proativo de uso de reservas, credit lines com BCB.

Risco de Crédito

Em operações onde uma instituição "deve" outra (ex: entre janelas de liquidação líquida no SILOC). Risco de uma quebrar e a outra ficar com prejuízo.

Mitigação: Pix mitiga isso porque liquida bruta em tempo real (sem janela de exposição entre instituições).

Risco de Fraude

Cliente A finge ser cliente B, golpes via engenharia social, contas laranja recebendo Pix de golpes.

Mitigação técnica: integração com `fraud-markers` do DICT, ML anti-fraude, validação de comportamento (limites por horário, padrão de gasto), MED.

Risco Cibernético

Ataque externo a APIs, vazamento de dados, ransomware.

Mitigação: mTLS, WAF, DDoS protection, hardening de servidores, pentests regulares.

Risco de Conduta

Empresa praticar venda casada, omitir taxas, dar informação falsa. Aqui é mais conduta humana que sistema.

Mitigação: treinamento, KYC robusto, monitoring de canais de atendimento.

Risco Sistêmico

Risco de uma falha em uma instituição grande contaminar o sistema todo. **O Pix tem essa preocupação porque é centralizado no BCB.**

Mitigação (do BCB): redundância do SPI, contingências, regras de SLA pesadas.

> 🔑 **Pra call:** quando cliente pergunta sobre risco, identifique **qual** risco. "Risco" sozinho não diz nada. **"Risco operacional do nosso cliente Pix"** ou **"risco cibernético do nosso endpoint DICT"** são frases concretas.

Capítulo 27 — Multas, sanções e enforcement

> ⚠️ **Advertência:** valores específicos de multa **mudam** com nova regulação. Os números abaixo são qualitativos pra você ter ideia de magnitude. **Em call, NÃO cite valor específico** sem ter checado o número atualizado nas Resoluções vigentes.

Quem aplica multa

- **BCB (Decon)** — para descumprimento de regras de Pix, Open Finance, DICT, SPB
- **Susep** — para descumprimento OPIN
- **CADE** — concorrência (se houver indícios de prática anticompetitiva)
- **CVM** — mercado de capitais

Magnitude qualitativa

- **Multas técnicas leves** (ex: SLA descumprido pontualmente): podem ser **dezenas a centenas de milhares de reais**

- **Multas pesadas** (descumprimento sistemático, dano ao consumidor): podem chegar a **milhões de reais**, com escalonamento por reincidência
- **Sanções não-monetárias:** suspensão de operação, restrição cautelar, descredenciamento

Onde a engenharia entra

Quase toda **multa técnica** é evitável com boa engenharia:

- SLA descumprido → resilience + capacity planning
- Vazamento de dados → mTLS + secrets management
- Não-conformidade ao manual → testes contratuais + ArchUnit + revisão de schema
- Auditoria reprovada → logs estruturados + retenção correta

> 🔑 **Frase poderosa pra call:** *"O custo de não-conformidade técnica não é só a multa direta — é o risco de ser descredenciado e perder a operação inteira. Por isso adequação não é despesa, é seguro."*

Capítulo 28 — mTLS e ICP-Brasil em profundidade

> Mesmo sem ser specialista em PKI, **você precisa saber explicar isso em call**. Toda integração regulatória crítica usa.

Por que mTLS?

TLS unilateral (HTTPS comum): o **cliente verifica** que o servidor é quem diz ser (cert do servidor). Servidor confia no cliente via outro mecanismo (ex: token).

mTLS — Mutual TLS: cliente verifica servidor **E** servidor verifica cliente, ambos com certs. Ninguém entra na conversa sem prova criptográfica de identidade.

Por que regulação financeira exige

- **Token vaza** → atacante consegue fingir ser o cliente
- **Cert privado vaza** → mais difícil (geralmente em HSM, hardware security module)
- mTLS dá **autenticação bilateral forte e baseada em hardware** (com certs em HSM)

O que é ICP-Brasil

Infraestrutura de Chaves Públicas Brasileira. PKI **soberana brasileira**, criada por lei e operada pelo ITI (Instituto Nacional de Tecnologia da Informação).

Estrutura:

```
Autoridade Certificadora Raiz Brasileira (AC-Raiz)
    │
    ├── AC Nível 2 (Serasa, Certisign, Soluti, etc.)
    │       │
    │       └── Cert da sua empresa (CN=XXX, CNPJ=...)
    │
    └── ... outras ACs
```

Pra obter cert ICP-Brasil:

1. Empresa contrata uma AC credenciada (ex: Certisign)
2. Faz **validação presencial** (alguém vai num posto de validação com docs da empresa)
3. Recebe cert em **token criptográfico físico** (pendrive USB) ou **HSM**
4. Cert é válido por X meses (geralmente 1–3 anos)

Custos típicos

- Cert ICP-Brasil A1 (em arquivo) = ~R$ 200–400/ano
- Cert ICP-Brasil A3 (em token) = ~R$ 300–600/ano
- HSM dedicado = R$ 10k–50k/ano

> ⚠️ **Pra dev:** em **homologação/sandbox** do BCB, geralmente você pode usar cert auto-assinado ou cert de uma CA test. **Em produção, é ICP-Brasil obrigatório**.

O que sua implementação precisa fazer

1. **Carregar o cert** (de arquivo, keystore, HSM, ou Vault)
2. **Validar a cadeia** do cert do servidor contra a cadeia ICP-Brasil
3. **Apresentar seu cert** na handshake TLS
4. **Renovar antes de expirar** (esquecer = perder produção, multa)
5. **Logs de toda chamada com cert ID** (auditoria)

No seu projeto `dict-client-reference`

Você usou **Spring Boot SSL Bundle** (`spring.ssl.bundle.jks.dict-prod`). É o método moderno e correto. Seu README diz "ICP-Brasil ready" — quando o cliente fornecer o cert/keystore real, é só apontar a config.

Capítulo 29 — Logs, auditoria e observabilidade regulatória

> Aqui mora um dos seus maiores diferenciais como dev consultor: **observabilidade séria**.

O que precisa ser logado (em ordem de criticidade)

1. **Cada chamada outbound** (Pix, DICT, Open Finance) — com request ID, payload hash, response status, latência
2. **Cada decisão de autorização** (ex: "rejeitamos pagamento porque saldo X")
3. **Cada erro de validação** — formato, schema, regra de negócio
4. **Mudanças de configuração** — quem mudou, quando, valor antigo vs novo
5. **Acessos administrativos** — login admin, mudança de chave, etc.

Formato

JSON estruturado (one-line-per-record). Por quê:

- Parseable por SIEM (Splunk, Elastic, Datadog)
- Fácil de filtrar
- Fácil de exportar pro auditor

```
{
  "timestamp": "2026-04-26T14:30:15.123Z",
  "level": "INFO",
  "trace_id": "abc-123-xyz",
  "service": "dict-client",
  "operation": "lookup",
  "key_type": "PHONE",
  "key_masked": "+55119****9999",
  "duration_ms": 187,
  "outcome": "SUCCESS",
  "cache_hit": false,
  "psp_target": "BCB-DICT-PROD"
}
```

> ⚠️ **NUNCA logue:** chave Pix completa, CPF/CNPJ completo, valor de transação ligado a CPF, números de cartão (mesmo parciais), credenciais. Tudo isso vai contra LGPD + regras BCB.

Retenção

Logs financeiros geralmente devem ser retidos por **5 anos** (verificar regra específica). Use armazenamento barato (S3 Glacier, Azure Cool Tier) pra logs frios.

Métricas que importam

- **Latência percentil 95 e 99** das chamadas a infra externa (DICT, SPI, OF)
- **Taxa de erro** por tipo (4xx, 5xx, timeouts)
- **Taxa de cache hit** (especialmente DICT)
- **Estado dos circuit breakers** (open, half-open, closed)
- **Reservas de capital usadas** (financeiro)
- **Volume de transações por minuto/hora**

Dashboards

Você implementou no `dict-client-reference`:

- `dict-overview` (11 painéis) — operação geral
- `dict-resilience` (10 painéis) — saúde dos circuit breakers, retry, rate limit

Isso é diferencial. Maioria dos repos open source brasileiros tem **logs e talvez Prometheus**, mas dashboard versionado como código é raro. Vende.

Tracing distribuído

Quando uma transação Pix passa por **3+ serviços** (cliente → backend → DICT → SPI → notificação), você precisa de **trace ID único** que cruza tudo.

Padrão: W3C Trace Context (`traceparent` header). Suportado pelo OpenTelemetry. Implementado nos seus repos.

Capítulo 30 — Padrões de implementação que sinalizam senioridade

> Esta seção é **ouro pra call técnica**. Cada um desses termos, usado corretamente, te diferencia.

1. Idempotência

Operação que pode ser executada **N vezes com o mesmo resultado**. Crítico em pagamentos: se um Pix der timeout, você não pode duplicar a cobrança ao reexecutar.

Como:

- Header `Idempotency-Key` (UUID gerado pelo cliente) em cada operação POST/PUT
- Servidor armazena resultado por TTL — se receber mesmo key, retorna resultado cacheado

- Camadas: API gateway, service, banco

2. Outbox Pattern

Pra **garantir entrega** de evento mesmo se o serviço cair: salva o evento numa tabela "outbox" na MESMA transação que muda o estado. Worker assíncrono consome a outbox e publica o evento (Kafka, webhook, etc.).

Por que importa: se você notifica cliente sobre Pix antes de garantir que salvou, e o serviço cai, você ficou inconsistente. Outbox previne isso.

3. Saga Orquestrada

Transação distribuída que **não pode ser ACID**. Ex: criar consent → autorizar → debitar → notificar. Se passo 3 falha, precisa **compensar** os passos 1 e 2.

Saga orquestrada: um **orquestrador central** comanda os passos e dispara compensações.

4. Circuit Breaker

Quando uma dependência (DICT, SPI) fica lenta/down, em vez de continuar batendo nela e propagando lentidão, **abre o circuito**: passa a falhar rapidamente. Depois de cooldown, tenta de novo.

Resilience4j é o padrão Java pra isso.

5. Bulkhead

Isolar pools de threads/conexões por **dependência ou criticidade**. Se DICT degrada, não consome todas as threads do app — só seu pool dedicado.

6. Retry com Backoff Exponencial

Falhou? Tenta de novo, **mas com delay crescente**. Evita "thundering herd" quando um service volta.

7. Hexagonal Architecture (Ports & Adapters)

Camada `domain/` não conhece Spring, JPA, HTTP. Toda integração externa entra via "port" (interface) e "adapter" (implementação concreta). **Permite testar regra de negócio sem subir Postgres ou DICT.**

Você usa ArchUnit no `dict-client-reference` pra **garantir** que essa regra não é violada acidentalmente.

8. Mascaramento

CPF, conta, valor, chave Pix sempre logados/exibidos **mascarados**. Padrão: mostra primeiro/último, esconde meio. `***123***`.

9. Sender-Constrained Tokens (mTLS)

Token OAuth só funciona com o **mesmo cert mTLS** que o pegou. Se vazar token, atacante não consegue usar (precisaria do cert privado também).

10. Conformance Suite

Quando o regulador (BCB, OFB, Susep) tem **suite de testes oficial**, você roda contra a sua implementação **antes de produção**. Resultado pode ser exigido em homologação.

> 🔑 **Quando você usar 3-4 desses termos numa call de 30min, naturalmente, seu interlocutor te credibiliza imediatamente como sênior. Não precisa decorar — precisa entender cada um e onde se aplica.**

> 📍 **Onde estamos:** OPIN, compliance, mTLS/ICP-Brasil, observabilidade e padrões cobertos. Faltou só uma parte: **o cheat sheet pra call** — perguntas, respostas, frases-modelo. Vamos lá.